

CENTRO UNIVERSITÁRIO MARTHA FALCÃO WYDEN
CURSO DE ENGENHARIA DE SOFTWARE
DISCIPLINA: INTRODUÇÃO À SEGURANÇA DA INFORMAÇÃO
PROFESSOR: RANYERE NEY OSÓRIO LIMA

SIMULADO ENADE - 10 QUESTÕES DISCURSIVAS

Alunos: Cauê Lima, Juan Valente, Felipe Costa, Jefferson e Lucas Gabriel
Turma: 3001
Período: 2026.2

QUESTÃO 1 - Cenário hospitalar

Um hospital sofre um ataque onde prontuários são criptografados e o acesso é bloqueado. Qual princípio da Tríade CID foi o alvo direto e qual a implicação imediata para o atendimento?

Resposta:

Disponibilidade. O dado não vazou e não foi alterado: ele continua lá, íntegro e secreto. O que o ransomware fez foi trancar a porta. Confidencialidade e Integridade seguem de pé, quem caiu foi a Disponibilidade.

Na prática o hospital volta para o papel. O médico atende sem histórico, sem alergia registrada e sem saber a medicação em uso. Aqui indisponibilidade não é prejuízo de caixa, é risco clínico: cirurgia adiada e paciente transferido.

Ressalva: se houve exfiltração antes da criptografia, o clássico da dupla extorsão, aí a Confidencialidade cai junto. Mas o alvo do bloqueio é a Disponibilidade.

Fundamentação: ISO/IEC 27001; A.5.29 segurança durante interrupção; A.5.30 prontidão de TIC para continuidade

QUESTÃO 2 - LGPD e consentimento

Uma empresa compartilha dados de clientes com parceiros sem aviso prévio. Segundo a LGPD, quais direitos do titular foram violados e qual a base legal necessária para tal ação?

Resposta:

Violou a transparência: o titular tinha direito de saber com quem seus dados iam parar. Direitos atropelados: o de informação sobre o uso compartilhado (art. 18, VII), o de livre acesso e o de se opor ao tratamento. Junto caem os princípios da finalidade e da transparência

do art. 6º, compartilhar com parceiro é tratamento novo, não é extensão automática do que o cliente autorizou lá atrás.

Base legal necessária: consentimento específico e destacado para aquele compartilhamento (art. 7º, I combinado com o art. 8º). Legítimo interesse (art. 7º, IX) até cabe em alguns casos, mas exige teste de balanceamento e transparência mesmo assim. E se o dado for sensível não tem conversa: só consentimento específico (art. 11).

Fundamentação: LGPD; art. 6º, 7º, 8º, 11 e 18, VII; ISO/IEC 27002; 5.34 privacidade e proteção de dados pessoais

QUESTÃO 3 - Engenharia social

Um funcionário fornece sua senha por telefone a um suposto técnico de TI. Analise a falha sob a ótica do elo mais fraco da segurança e proponha uma medida preventiva não tecnológica.

Resposta:

Nenhum controle técnico falhou. Falhou a pessoa, e é por isso que ela é o elo mais fraco. O firewall, o antivírus e a criptografia continuaram funcionando perfeitamente. O invasor não quebrou nada: ele pediu, e entrou pela porta da frente com credencial válida. Manipular gente sai mais barato que tentar quebrar AES.

Medida preventiva não tecnológica: treinamento periódico de conscientização, apoiado numa política escrita e repetida de que a TI nunca pede senha, mais o procedimento de desligar e retornar pelo ramal oficial antes de passar qualquer informação.

E um detalhe que muita empresa erra: não punir quem reporta. Funcionário com medo esconde o incidente, e incidente escondido vira incidente grande.

Fundamentação: ISO/IEC 27002; 6.3 conscientização e treinamento; 5.1 políticas de segurança; 6.8 relato de eventos

QUESTÃO 4 - Hash e integridade

Ao baixar um software, o site fornece um "hash" (SHA-256). Explique como o uso desse hash garante a integridade do arquivo e o que um hash diferente indicaria ao usuário.

Resposta:

O hash é a impressão digital do arquivo. Bateu, é bit a bit o que o autor publicou. Baixo o arquivo, calculo o SHA-256 na minha máquina e comparo com o publicado. A função é determinística e tem efeito avalanche: muda um único bit do arquivo e o hash inteiro muda. Não existe "quase igual".

Hash diferente quer dizer que o arquivo que chegou não é o que saiu. Pode ser download corrompido ou pode ser adulteração, alguém trocou o instalador por um com backdoor. Nos dois casos a decisão é a mesma: não instala.

Ressalva importante: hash sozinho garante integridade, não autenticidade. Se o atacante domina o site, ele troca o arquivo e o hash junto. Por isso o hash precisa vir por canal confiável, e o ideal é assinatura digital.

Fundamentação: ISO/IEC 27002; 8.24 uso de criptografia; Tríade CID; Integridade

QUESTÃO 5 - Classificação de informação

Uma empresa classifica seus dados em: Público, Interno e Confidencial. Relacione essa classificação com o controle de acesso e o impacto de um vazamento em cada nível.

Resposta:

O nível vem do impacto do vazamento, e o controle de acesso vem do nível. Público: circula livre, sem controle de acesso, porque já nasceu para ser visto. Vazou, não acontece nada.

Interno: só colaborador autenticado. Vazou, constrange e expõe processo, mas não gera multa nem perde contrato.

Confidencial: acesso mínimo, need to know, registro de quem abriu e criptografia. Vazou, dói no caixa, na LGPD e na imagem. E o descarte muda junto: aqui não basta apagar, tem que sobrescrever ou triturar.

Rotular é decidir de antemão quanto custa perder aquele ativo. Proteção proporcional ao impacto, nem paranoia, nem descuido.

Fundamentação: ISO/IEC 27002; 5.12 classificação; 5.13 rotulagem; 5.15 controle de acesso; 8.10 exclusão de informações

QUESTÃO 6 - Ameaça, vulnerabilidade e risco

Diferencie os conceitos de Ameaça, Vulnerabilidade e Risco. Como a implementação de um firewall atua sobre esses elementos em um cenário de invasão externa?

Resposta:

Ameaça eu não controlo. Vulnerabilidade eu controlo. Risco é o encontro dos dois. Ameaça é o agente ou evento que pode causar dano: o invasor existe querendo eu ou não. Vulnerabilidade é a minha fraqueza que ele explora, tipo uma porta de administração remota aberta para a internet. Risco é probabilidade vezes impacto, sem vulnerabilidade para explorar, a ameaça fica só ameaça.

O firewall não age na ameaça, age na vulnerabilidade: fecha porta, filtra serviço exposto e encolhe a superfície de ataque. Isso derruba a probabilidade, e derrubando probabilidade derruba o risco.

O invasor continua lá tentando. O que sobra depois do controle é o risco residual, que a empresa aceita formalmente ou trata de novo.

Fundamentação: ISO/IEC 27001; 6.1.2 avaliação e 6.1.3 tratamento de riscos; ISO/IEC 27005; 27002; 8.20 segurança de redes

QUESTÃO 7 - RTO e RPO

Após um incêndio no datacenter, a empresa ativa seu site de backup. Explique a importância do RTO (Recovery Time Objective) e do RPO (Recovery Point Objective) neste processo.

Resposta:

RTO é quanto tempo eu aguento parado. RPO é quanto dado eu aceito perder. O RTO conta para frente a partir do desastre e define quanto investir em infraestrutura: site quente sobe em minutos e custa caro, site frio é barato e demora dias. O RPO conta para trás e define a frequência de backup ou replicação, RPO de uma hora significa cópia de hora em hora, no mínimo.

Sem esses dois números definidos antes, o plano de continuidade é achismo: não dá para dizer se o site de backup atende. Um banco trabalha com RPO perto de zero porque não pode perder transação; uma papelaria sobrevive com RTO de dois dias.

Fundamentação: ISO/IEC 27001; A.5.29 e A.5.30; ISO 22301 continuidade de negócio

QUESTÃO 8 - Backup que ninguém testou

Uma empresa realiza backups diários, mas nunca testou a restauração. Analise o risco envolvido e como isso impacta a garantia do princípio da Disponibilidade.

Resposta:

Backup que nunca foi restaurado não é backup, é esperança. Você só descobre que a cópia está corrompida na hora do desastre, que é exatamente o pior momento para descobrir. E as formas de falhar são banais: job falhando em silêncio há meses, base que ficou fora do escopo, mídia degradada, backup criptografado com uma chave que ninguém sabe onde está.

A Disponibilidade não é garantida pelo backup existir, é garantida pela restauração funcionar. Enquanto ninguém restaurou, o controle existe no papel e não existe na prática, e ainda cria falsa sensação de segurança, que é pior do que não ter.

Correção: teste de restauração periódico, documentado e cronometrado. O cronômetro mede o RTO real e diz se ele bate com o que foi prometido.

Fundamentação: ISO/IEC 27002; 8.13 backup de informações; 5.29 segurança durante interrupção

QUESTÃO 9 - Auditoria interna e PDCA

Qual o papel da auditoria interna na manutenção da certificação ISO 27001? Explique como o ciclo PDCA (Plan-Do-Check-Act) se aplica à Segurança da Informação.

Resposta:

A auditoria interna é o C do PDCA: a empresa se olhando no espelho antes do auditor externo olhar. Ela confere se o que está escrito na política é o que acontece no dia a dia. Certificação não se ganha uma vez e pendura na parede: ela é mantida, e é auditada de novo periodicamente.

No ciclo: Plan define escopo, analisa risco, escolhe controles e assina a Declaração de Aplicabilidade. Do implementa e opera. Check monitora, mede e audita. Act corrige a não conformidade, e a correção vira entrada do próximo Plan.

Sem o Check o SGSI vira documento morto. O achado da auditoria é o combustível do Act, é o que faz aquilo girar como ciclo em vez de virar linha reta.

Fundamentação: ISO/IEC 27001; 9.2 auditoria interna; 9.3 análise crítica pela direção; 10 melhoria

QUESTÃO 10 - Governança e alta gestão

Relacione a Segurança da Informação com a Governança Corporativa. Por que a segurança deve ser uma preocupação da alta gestão e não apenas do departamento de TI?

Resposta:

Segurança é decisão de risco de negócio. E risco de negócio é da diretoria, não do analista. Quem aceita risco precisa ter autoridade para aceitar. Nenhum analista decide sozinho que a empresa vai conviver com o risco de uma multa de LGPD, isso é assinatura de quem responde pela empresa.

Tem o lado prático: sem patrocínio da alta gestão, segurança perde toda disputa por orçamento e vira o setor que atrasa projeto. E tem o lado legal: a LGPD responsabiliza o controlador, ou seja a empresa e seus dirigentes, não o técnico que configurou o servidor.

Fora que segurança atravessa RH (admissão e desligamento), Jurídico (contrato e cláusula) e Financeiro. Só a alta gestão tem alcance para atravessar área, por isso a ISO 27001

põe o comprometimento da Alta Direção como requisito, não como sugestão.

Fundamentação: ISO/IEC 27001; 5.1 liderança e comprometimento; LGPD art. 42 a 45;
ISO/IEC 27002; 5.4 responsabilidades da direção